Security Incident Report

This is a Security Incident Report for a fictional scenario given as an activity for the *Connect and Protect: Networks and Network Security Course* in Coursera

Scenario:
You are a cybersecurity analyst for yummyrecipesforme.com, a website that sells recipes and cookbooks. A former employee has decided to lure users to a fake website with malware.

The former employee/ hacker executed a brute force attack to gain access to the web host. They repeatedly entered several known default passwords for the administrative account until they correctly guessed the right one. After they obtained the login credentials, they were able to access the admin panel and change the website's source code. They embedded a javascript function in the source code that prompted visitors to download and run a file upon visiting the website. After embedding the malware, the hacker changed the password to the administrative account. When customers download the file, they are redirected to a fake version of the website that contains the malware.

Several hours after the attack, multiple customers emailed yummyrecipesforme's helpdesk. They complained that the company's website had prompted them to download a file to access free recipes. The customers claimed that, after running the file, the address of the website changed and their personal computers began running more slowly.

In response to this incident, the website owner tries to log in to the admin panel but is unable to, so they reach out to the website hosting provider. You and other cybersecurity analysts are tasked with investigating this security event.

To address the incident, you create a sandbox environment to observe the suspicious website behavior. You run the network protocol analyzer tcpdump, then type in the URL for the website, yummyrecipesforme.com. As soon as the website loads, you are prompted to download an executable file to update your browser. You accept the

download and allow the file to run. You then observe that your browser redirects you to a different URL, greatrecipesforme.com, which contains the malware.

The logs show the following process:

1. The browser initiates a DNS request: It requests the IP address of the yummyrecipesforme.com URL from the DNS server.
2. The DNS replies with the correct IP address.
3. The browser initiates an HTTP request: It requests the yummyrecipesforme.com webpage using the IP address sent by the DNS server.
4. The browser initiates the download of the malware.
5. The browser initiates a DNS request for greatrecipesforme.com.
6. The DNS server responds with the IP address for greatrecipesforme.com.
7. The browser initiates an HTTP request to the IP address for greatrecipesforme.com.

A senior analyst confirms that the website was compromised. The analyst checks the source code for the website. They noticed that javascript code had been added to prompt website visitors to download an executable file. Analysis of the downloaded file found a script that redirects the visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com.

The cybersecurity team reports that the web server was impacted by a brute force attack. The disgruntled hacker was able to guess the password easily because the admin password was still set to the default password. Additionally, there were no controls in place to prevent a brute force attack.

Your job is to document the incident in detail, including identifying the network protocols used to establish the connection between the user and the website. You should also recommend a security action to take to prevent brute force attacks in the future.

Link for tcpdump log: tcpdump traffic log

Section 1: Identify the network protocol involved in the incident
The network protocol identified in the tcpdump log is the HTTP, seen on port 80. HTTP works at the application layer of the TCP/IP model and uses TCP at the transport layer to make the connection. The log also shows the DNS, which turned the website names into IP addresses before each HTTP request.

Section 2: Document the incident
A former employee gained access to the administrative account for the web host of yummyrecipesforme.com using a brute force attack. They entered known default passwords until one worked. The admin password had never been changed from its default, and no controls were in place to limit repeated login attempts. After logging in, the attacker edited the website's source code and added JavaScript that prompts visitors to download and run an executable file. They then changed the admin password. Several hours after the attack, multiple customers emailed the helpdesk. They reported that the website prompted them to download a file to get free recipes, that the website address changed after they ran the file, and that their computers began running more slowly. The website owner then found they could not log in to the admin panel and contacted the website hosting provider. The analysts tested the website in a sandbox environment while running tcpdump. The log shows this sequence: 1. 14:18:32: DNS request for yummyrecipesforme.com. The DNS server (dns.google) replied at 14:18:32 with the IP address 203.0.113.22. 2. 14:18:36: The browser made an HTTP request (GET /) to yummyrecipesforme.com on port 80. 3. The browser was prompted to download an executable file and the download was started. This step is described in the scenario and is not visible in the log excerpt. 4. 14:20:32: DNS request for greatrecipesforme.com. The DNS server replied with the IP address 192.0.2.17. 5. 14:25:29: The browser made an HTTP request (GET /) to greatrecipesforme.com on port 80.

A senior analyst checked the website's source code and confirmed that JavaScript had been added to prompt visitors to download an executable file. Analysis of the downloaded file found a script that redirects visitors from yummyrecipesforme.com to greatrecipesforme.com.

Section 3: Recommend one remediation for brute force attacks
I recommend a Password Policy for all admin accounts. In this incident, the admin password was still set to the default, so the attacker was able to guess it using a list of known default passwords. The Password Policy would require that default passwords be changed before an account is used, and that new passwords be long, hard to guess, not reused, and changed on a set schedule. This is effective against brute force attacks because each extra character and each banned common password greatly increases the number of guesses an attacker would need to try, and a default password stops working as a guess once it has been replaced.